# Manual del auditor(a)

El rol de auditor tiene **acceso de solo lectura**. Puede consultar expedientes, documentos vigentes, delegaciones de firma, comunicaciones oficiales y el panel de seguridad, pero **no puede crear, modificar, firmar, derivar, cerrar ni subir nada**. Todo acceso suyo también queda auditado.

## 1. Qué puede ver

| Sección | Qué contiene |
|---|---|
| **Bandeja** | Los expedientes del sistema (lectura). |
| **Documentos vigentes** | Todos los documentos con flujo completo: número, fecha, expediente, nivel de acceso, enlace público de validación. |
| **Comunicaciones oficiales** | Lo recibido por DocDigital y su acuse de recibo. |
| **Delegaciones de firma** | Quién tiene delegación, para qué tipo, con qué decreto y vigencia. |
| **Seguridad** | Verificación de la cadena de auditoría, últimos eventos e incidentes. |
| **Conexiones y mapa** | Mapa por país y ranking de IP (entrantes y salientes), con errores y tipo de uso; útil para detectar escaneos. Datos por hora, sin URL ni contenido. |
| **Componentes y librerías** | Versiones de cada librería y activo, verificación de «sin CDN» e inventario descargable (JSON). |
| **Registro de logs** | Búsqueda con filtros (fecha, acción, rol, RUN, entidad, IP) y exportación CSV (queda registrada). |

Puede abrir un expediente, ver sus **metadatos**, el **índice con huellas SHA-256**, los documentos y sus **versiones inmutables**, las firmas y las notificaciones con su evidencia, y **descargar** archivos (cada descarga se registra como acceso sensible).

## 2. Verificar la cadena de auditoría

1. Menú **Seguridad → Verificar cadena de auditoría (HMAC)**.

2. El resultado indica el total de registros verificados o el **primer registro roto**.
3. **Interpretación:** cada registro incluye el hash del anterior y un HMAC con una clave que no está en la base de datos. Si alguien modifica o borra un registro, la cadena se rompe en ese punto.
4. Si está **rota**, avise de inmediato al administrador y al encargado de ciberseguridad para registrar un incidente (**no** modifique ni borre nada; preserve evidencia).

El sistema también verifica la cadena cada noche automáticamente.

## 3. Revisar eventos

En **Seguridad → Últimos eventos** verá fecha, rol, acción, entidad e IP. Acciones relevantes: `auth.login`, `auth.fallo`, `documento.firmar`, `documento.vigente`, `expediente.ver`, `archivo.descarga`, `seguridad.csrf_fallido`, `seguridad.acceso_denegado`, `seguridad.error_500`, `pisee.consulta`, `docdigital.*`, `mantenedor.*`, `delegacion.*`. Los secretos, OTP y datos sensibles **no** se registran en el detalle.

## 4. Incidentes

La sección **Incidentes** muestra cada incidente con su severidad, estado y los hitos de reporte al CSIRT Nacional (alerta temprana, segundo reporte, informe final). Usted los consulta; solo el administrador los crea y actualiza.

## 5. Qué revisar en una auditoría típica

- **Firma:** que cada documento vigente tenga sus pasos completos, firmantes habilitados y, para decretos alcaldicios, firmante alcalde o delegado con **delegación vigente** en la fecha.
- **Numeración:** correlativo continuo por tipo y año (sin saltos ni repeticiones).
- **Integridad:** huellas SHA-256 del documento coincidentes con la copia pública y con la hoja de certificado; versiones inmutables.
- **Notificaciones:** cada notificación "enviada" tiene evidencia (ID de Gmail, ID de Casilla Única o acta). Ninguna "pendiente" figura como enviada.
- **Comunicaciones DocDigital:** cada recibida tiene expediente, acuse registrado y respuesta (si correspondía); cada enviada tiene ID de envío.
- **Accesos a datos sensibles:** `expediente.ver` y `archivo.descarga` por personas que no son de la unidad deberían estar justificados por derivación.
- **Consultas PISEE:** finalidad registrada y solo al solicitante.

## 6. Accesibilidad

Barra superior con tamaño de texto, alto contraste, texto legible, subrayado de enlaces y sin animaciones. Las tablas tienen encabezados de columna para lectores de pantalla.

## 7. Preguntas frecuentes

**No puedo editar nada.** Es lo esperado: el rol es de solo lectura.

**No veo un expediente.** El auditor ve todos; si falta alguno, verifique que no sea un error de búsqueda y avise al administrador.

**¿Puedo exportar los metadatos?** Sí: en el expediente, **Exportar metadatos (JSON)**; la exportación queda auditada.

## Accesos a contenido restringido

Si su rol lo incluye, **Accesos a restringidos** lista los accesos permitidos y los intentos denegados a expedientes, documentos y archivos restringidos, con filtros por persona, expediente, resultado y fechas. Úselo para detectar consultas indebidas. Los datos personales se muestran minimizados (RUN parcial, sin IP).